

Mapeo GQM de preguntas de encuesta COBIT a requisitos normativos

A partir del modelo de encuesta COBIT y de los indicadores asociados, se mapea cada pregunta a su objetivo COBIT, Goal GQM, métricas y marcos normativos relevantes.[web:18][web:24][web:43]

1. Estructura del mapeo

Cada fila de la tabla recoge:

- Pregunta de la encuesta.
- Goal GQM al que contribuye.
- Objective COBIT principal.
- Métrica(s) asociadas.
- Normas / marcos de referencia.

2. Tabla de mapeo

| Pregunta encuesta | Goal GQM | Objetivo COBIT | Métrica(s) asociadas | Normas /
marcos relacionados |
| --- | --- | --- | --- | --- |
| P1.1.1 Frecuencia de revisión de ciberseguridad por el órgano de gobierno | G1 -
Optimizar riesgo de ciberseguridad vía supervisión efectiva | EDM03 - Ensured Risk
Optimization | M1.1 N° reuniones/año con ciberseguridad en la agenda | NIS2
(gobernanza), ENS (principios), códigos de buen gobierno |
| P1.1.2 Informes de ciberseguridad al órgano de gobierno | G1 | EDM03, MEA01 | M1.2
Nivel de formalización de informes | NIS2 (gestión de riesgos), ISO 27001 (5.1, 9.3) |
| P1.2.1 Declaración de apetito y tolerancia al riesgo | G1 | EDM03, AP012 | M2.1
(indirecta) madurez del proceso de riesgo; indicador booleano de existencia | ISO
31000, COSO ERM, NIS2 |
| P1.2.2 Revisión del apetito al riesgo | G1 | EDM03 | Métrica de frecuencia de
revisión (ordinal) | ISO 31000, buenas prácticas de gobierno |
| P2.1.1 Proceso formal de gestión de riesgos de TI | G2 - Gestionar sistemáticamente
el riesgo de TI | AP012 - Managed Risk | M2.1 Grado de formalización del proceso | ISO
27001 (cláusulas 6 y 8), ENS, NIS2 |
| P2.1.2 Cobertura del proceso (tipos de riesgos) | G2 | AP012 | Métrica de alcance
del proceso de riesgo (escala ordinal) | ISO 27005, NIST SP 800-30 |
| P2.2.1% de activos críticos con análisis de riesgos vigente | G2 | AP012 | M2.2%
activos críticos con análisis de riesgos actualizado | ISO 27001 (A.8), ENS (ANEXO II)
|
| P2.2.2 Frecuencia de revisión de análisis de riesgos | G2 | AP012, MEA01 | Métrica
de frecuencia de revisión (ordinal) | ISO 27005, ENS |
| P3.1.1 Existencia y madurez del SGSI | G3 - Implantar SGSI efectivos | AP013 -
Managed Security | M3.1 Nivel de madurez del SGSI | ISO 27001, ENS, NIS2 |
| P3.1.2 Alineamiento / certificación ISO 27001 | G3 | AP013 | M3.2 Nivel de
alineamiento/certificación | ISO 27001, esquemas nacionales de certificación |
| P3.2.1 Función de seguridad (CISO) | G3 | AP013, EDM03 | Métrica de formalización
del rol CISO (ordinal) | NIS2 (responsabilidades), ENS (organización) |
| P3.2.2% presupuesto TI dedicado a seguridad | G3 | AP013, EDM03 | M3.3% presupuesto
TI en seguridad | Buenas prácticas de gobernanza TI, informes sectoriales |
| P4.1.1% cambios críticos con evaluación de seguridad | G4 - Cambios de TI seguros |
BAI06 - Managed IT Changes | M4.1% cambios con evaluación de seguridad | ISO 27001
(A.8, A.14), ITIL, ENS |
| P4.1.2 Pruebas de seguridad asociadas a cambios | G4 | BAI06, DSS05 | Métrica de
nivel de integración de pruebas de seguridad en cambios | ISO 27001 (A.12, A.14),
guías DevSecOps |
| P4.2.1 Incidentes por cambios mal gestionados | G4 | BAI06, DSS02 | M4.2% incidentes
atribuibles a cambios | ISO 27001 (A.16), NIST CSF (Identify/Protect) |
| P5.1.1 Capacidades SOC / monitorización | G5 - Servicios de seguridad eficaces |
DSS05 - Managed Security Services | M5.1 Nivel de madurez SOC | NIS2 (detección), ENS
(detección), NIST CSF (Detect) |
| P5.1.2 MTTD de incidentes | G5 | DSS05, MEA01 | M5.2 Tiempo medio de detección |
NIST CSF (Detect, Respond), guías de métricas de seguridad |
| P5.2.1 MTTR de incidentes | G5 | DSS05, DSS02 | M5.2 Tiempo medio de respuesta |
NIST CSF (Respond, Recover), ISO 27035 |
| P5.2.2% vulnerabilidades críticas resueltas en plazo | G5 | DSS05, AP012 | M5.3%
vulnerabilidades críticas resueltas dentro del SLA | ISO 27001 (A.12), NIST SP 800-40
|
| P6.1.1 Estado y pruebas de BCP/DRP | G6 - Mejorar resiliencia y continuidad | DSS04
- Managed Continuity | M6.1 Nivel de pruebas de continuidad | ISO 22301, ISO 27001
(A.17), ENS |
| P6.1.2 Simulacros de ciber crisis con dirección | G6 | DSS04, EDM03 | M6.2 Frecuencia
de simulacros | NIST CSF (Respond/Recover), guías nacionales de ciberresiliencia |
| P7.1.1 Cuadro de mando de ciberseguridad | G7 - Monitorizar y mejorar | MEA01 -
Performance and Conformance Monitoring | M7.1 Nivel de formalización del cuadro de
mando | ISO 27004, NIS2 |
| P7.1.2 Periodicidad de revisión de indicadores | G7 | MEA01, EDM03 | Métrica de
frecuencia de revisión (ordinal) | Buen gobierno TI, ISO 27004 |

P7.2.1 Frecuencia de auditorías de seguridad	G7	MEA02 - System of Internal Control	M7.2 Frecuencia de auditorías	ISO 27001 (auditoría interna), ENS, normas sectoriales
P7.2.2% acciones correctivas cerradas en plazo	G7	MEA02, MEA03 - Compliance	M7.3% acciones correctivas cerradas a tiempo	ISO 27001 (no conformidades), marcos de compliance
P8.1 Madurez global autoevaluada	G1-G7 (transversal)	Todos (CPM COBIT 2019)	Métrica de madurez global 0-5	COBIT 2019 Performance Management
P8.2 / P8.3 Fortalezas y debilidades	G1-G7	Transversal	Métricas cualitativas (texto libre)	Planes estratégicos nacionales, NIS2, ENS

Fin del mapeo.